
Cuadernillo de Estudio — Clase 5

Práctica de Análisis y Matriz de Riesgos: Revisión de Casos

Seguridad Aplicada a Sistemas de Información
 Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
 Docente: Ing. Rodrigo Atilio Elgueta
 Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. De la Teoría a la Práctica: El Análisis Post-Mortem	2
3. Caso de Estudio: “El Eslabón más Débil” (RetailCorp)	2
3.1. Contexto	2
3.2. El Incidente	3
3.3. Las Alertas Ignoradas	3
4. Guía de Revisión: Identificando Prácticas	3
4.1. Inventario de Activos Comprometidos	3
4.2. Identificación de Malas Prácticas (Vulnerabilidades Sistémicas)	3
4.3. Propuesta de Buenas Prácticas (Salvaguardas)	4
5. Glosario de conceptos clave aplicados al caso	4
6. Autoevaluación	4
7. Respuestas de la Autoevaluación	5
8. Recordatorio: Actividad A04	6
9. Fuentes y bibliografía	7
9.1. Bibliografía obligatoria (según programa)	7
9.2. Bibliografía complementaria y Marcos de Trabajo	7
9.3. Portales y recursos web	7

1. Objetivos de aprendizaje

Al finalizar la lectura y el trabajo con este cuadernillo, el estudiante será capaz de:

- Aplicar la metodología de **análisis post-mortem** para evaluar incidentes de seguridad reales.
- Elaborar documentos de gestión de riesgos a partir de la narrativa de un caso de estudio.
- Identificar y documentar **malas y buenas prácticas** en el diseño de infraestructuras y procesos.
- Mapear las fallas de un caso real utilizando la **Matriz de Riesgos** y proponer salvaguardas correctivas.
- Preparar la revisión y presentación del caso para la **Actividad A04**.

Cómo usar este cuadernillo

En la Clase 4 aprendimos la teoría y las fórmulas del riesgo. En esta Clase 5, nos ponemos el rol de **auditores y consultores**. Leeremos un caso de estudio real (anonimizado), diseccionaremos qué salió mal y prepararemos el terreno para tu entrega de la Actividad A04. Las respuestas de la autoevaluación están en la Sección 7.

2. De la Teoría a la Práctica: El Análisis Post-Mortem

En la industria de la ciberseguridad, cuando ocurre un incidente grave, no basta con «apagar el incendio». Las organizaciones maduras realizan un **análisis post-mortem** (o lecciones aprendidas).

Análisis Post-Mortem

Proceso estructurado que se realiza después de un incidente de seguridad o una falla de riesgo para determinar: qué ocurrió, por qué ocurrió, qué impacto tuvo y, lo más importante, **qué cambios sistémicos** se deben implementar para que no vuelva a suceder.

El objetivo de revisar casos de estudio en la universidad es entrenar el ojo crítico. Un profesional junior ve «un servidor hackeado». Un profesional senior ve «una falla en la segmentación de red sumada a una ausencia de autenticación multifactor en accesos de terceros».

3. Caso de Estudio: “El Eslabón más Débil” (RetailCorp)

Leé atentamente el siguiente caso. Está basado en hechos reales de la industria retail.

3.1. Contexto

RetailCorp es una cadena de supermercados con presencia nacional. Tienen su casa central, un data center propio y cientos de sucursales. Para mantener los servidores de las sucursales en condiciones óptimas, tercerizan el servicio de climatización (HVAC) con la empresa **ClimaTech**.

Para que los técnicos de ClimaTech puedan monitorear las temperaturas de los servidores de forma remota, RetailCorp les otorga acceso a un **portal web de proveedores**. Desde este portal, los técnicos pueden ver alertas de temperatura y reiniciar las unidades de aire acondicionado.

3.2. El Incidente

Un empleado de ClimaTech recibe un correo de *phishing* muy convincente y entrega sus credenciales de acceso al portal de proveedores. Los atacantes (un grupo de ciberdelito organizado) ingresan al portal.

Una vez dentro, descubren que el portal de proveedores no está aislado. Encuentran una ruta de red que les permite «saltar» desde el servidor de climatización hacia la red corporativa interna. Desde allí, despliegan un malware en los **servidores de Point of Sale (POS)** (las cajas registradoras), logrando interceptar y robar los datos de millones de tarjetas de crédito de los clientes durante varias semanas.

3.3. Las Alertas Ignoradas

Lo más grave del caso es que RetailCorp **tenía** un sistema de detección de intrusos (IDS) de última generación. El IDS detectó el tráfico anómalo y generó alertas de «Malware conocido instalándose en red POS». Sin embargo, el Centro de Operaciones de Seguridad (SOC) de RetailCorp estaba subcontratado y sufría de **fatiga de alertas** (recibían miles de falsos positivos diarios). Los analistas asumieron que era otro falso positivo y archivaron la alerta sin investigar.

4. Guía de Revisión: Identificando Prácticas

Como auditores, debemos extraer los componentes de riesgo y clasificar las acciones de la organización.

4.1. Inventario de Activos Comprometidos

- **Activos de Información:** Datos de tarjetas de crédito (PCI-DSS), credenciales de empleados.
- **Activos de Software/Hardware:** Servidores POS, Portal de Proveedores.
- **Activos Intangibles:** Reputación de la marca, confianza del cliente, multas regulatorias.

4.2. Identificación de Malas Prácticas (Vulnerabilidades Sistémicas)

Mala Práctica 1: Falta de Segmentación de Red

El portal de un proveedor externo (de bajo nivel de confianza) tenía conectividad directa o rutas habilitadas hacia la red crítica de cobros (POS). **Regla de oro:** Los terceros solo deben acceder estrictamente a los recursos que necesitan para su función (Principio de Mínimo Privilegio).

Mala Práctica 2: Ausencia de MFA y Gestión de Terceros

El acceso al portal de proveedores dependía únicamente de una contraseña (algo que el usuario sabe). No había Autenticación Multifactor (MFA). Además, RetailCorp no audita las prácticas de seguridad de sus proveedores (Riesgo de Cadena de Suministro).

Mala Práctica 3: Fatiga de Alertas y Procesos del SOC

Tener un IDS caro no sirve de nada si el proceso administrativo (la revisión humana) falla. Ignorar alertas críticas por exceso de ruido es una falla de **gestión de riesgos operativos**.

4.3. Propuesta de Buenas Prácticas (Salvaguardas)

- **Técnica (Mitigación):** Implementar VLANs y Firewalls internos (microsegmentación) para que la red HVAC no pueda enrutar tráfico hacia la red POS.
- **Técnica (Mitigación):** Exigir MFA (token o app) para todos los accesos externos, especialmente para terceros.
- **Administrativa (Mitigación):** Ajustar las reglas del IDS para reducir falsos positivos y establecer un SLA (Acuerdo de Nivel de Servicio) que obligue al SOC a investigar alertas críticas en menos de 15 minutos.
- **Administrativa (Transferencia/Control):** Obligar a los proveedores a firmar cláusulas de ciberseguridad y realizar auditorías anuales a sus sistemas.

5. Glosario de conceptos clave aplicados al caso

Riesgo de Terceros (Supply Chain) Vulnerabilidades introducidas en la organización a través de proveedores, socios o software de terceros.

Segmentación de Red Práctica de dividir la red en zonas de seguridad para limitar el movimiento lateral de un atacante.

Fatiga de Alertas Fenómeno donde los analistas de seguridad ignoran alertas legítimas debido al alto volumen de falsos positivos generados por herramientas mal configuradas.

Movimiento Lateral Técnicas que usa un atacante para moverse a través de la red buscando activos críticos después de haber comprometido un punto de entrada inicial.

Post-Mortem Reunión y documento de análisis tras un incidente para extraer lecciones aprendidas.

6. Autoevaluación

Respondé por escrito. Este ejercicio es la base para la discusión en el aula y para tu informe A04.

1. En el caso RetailCorp, ¿por qué se dice que el riesgo no fue solo «técnico» sino también «administrativo»? Mencioná al menos dos fallas administrativas.
2. Si fueras el Gerente de IT de RetailCorp y tuvieras que justificar el presupuesto para implementar **Segmentación de Red** ante el Directorio, ¿cómo usarías los conceptos de **Impacto** y **Probabilidad** para defender tu inversión?
3. ¿Qué es la **Fatiga de Alertas** y cómo afecta a la salvaguarda técnica (el IDS)? ¿De qué tipo es la salvaguarda necesaria para corregir este problema?
4. Aplicando la **Matriz de Riesgos**, ¿en qué cuadrante (Nivel) ubicarías el riesgo de Robo de datos de tarjetas por acceso de terceros sin MFA” *antes* del incidente? ¿Por qué?

7. Respuestas de la Autoevaluación

Nota para el estudiante

Utilizá estas respuestas para contrastar tu análisis. En la revisión de casos en clase, se valorará tu capacidad de argumentar y debatir estas posturas.

Pregunta 1: Fallas Administrativas en el caso

Respuesta

El riesgo no fue solo técnico porque las tecnologías de seguridad (como el IDS) estaban presentes, pero fallaron los **procesos humanos y de gestión**. Dos fallas administrativas claras son:

1. **Gestión de Terceros / Contratos:** No haber exigido a ClimaTech estándares de seguridad (como MFA o capacitación anti-phishing) ni auditar sus accesos.
2. **Gestión del SOC y Procedimientos:** La falta de un protocolo estricto de respuesta a incidentes que obligara a investigar las alertas críticas del IDS, permitiendo que la "fatiga de alertas" dictara la seguridad de la empresa.

Pregunta 2: Justificación de Presupuesto (Impacto vs. Probabilidad)

Respuesta

Para defender la inversión ante el Directorio, el argumento basado en riesgos es:

- **Probabilidad:** «Es *casi seguro* (Probabilidad 5) que algún proveedor sufra un compromiso en sus credenciales en los próximos años, ya que el phishing es la vía de ataque más común y está fuera de nuestro control directo.»
- **Impacto:** «Si eso ocurre y tienen acceso a nuestra red POS, el impacto es *catastrófico* (Impacto 5): multas millonarias por la ley de protección de datos, demandas colectivas y daño reputacional irreversible.»
- **Conclusión (Riesgo Crítico):** «Al implementar Segmentación de Red, no reducimos la probabilidad de que hackeen al proveedor, pero **reducimos el Impacto a 'Insignificante'**, ya que el atacante quedará atrapado en la red de climatización sin poder tocar las cajas registradoras. La inversión en segmentación es una fracción del costo de un solo día de operación detenida.»

Pregunta 3: Fatiga de Alertas y tipo de salvaguarda

Respuesta

La **Fatiga de Alertas** ocurre cuando los analistas de seguridad se ven abrumados por un volumen masivo de alertas (muchas de ellas falsos positivos), lo que los lleva a ignorar o archivar alertas legítimas por agotamiento cognitivo. Esto **anula la efectividad de la salvaguarda técnica** (el IDS), porque de nada sirve que el sistema detecte el malware si el humano no actúa. Para corregir esto, la salvaguarda necesaria es de tipo **Administrativa**: rediseñar el proceso de "Tuning" (ajuste) del IDS para eliminar falsos positivos, y establecer

un SLA (procedimiento obligatorio) que exija la investigación formal de cualquier alerta clasificada como Crítica”.

Pregunta 4: Ubicación en la Matriz de Riesgos

Respuesta

Antes del incidente, si se hubiera hecho un análisis de riesgos honesto, este riesgo debió ubicarse en el cuadrante **CRÍTICO (Rojo)**.

- **Probabilidad: Alta (4) o Casi Segura (5).** Los accesos de terceros por web son vectores de ataque conocidos y el phishing es cotidiano.
- **Impacto: Catastrófico (5).** Se trata de datos financieros de clientes (tarjetas de crédito), lo que conlleva el cese de operaciones, multas legales y pérdida de confianza.

Un riesgo $5 \times 5 = 25$ exige un tratamiento inmediato (mitigación obligatoria) y escalamiento a la alta dirección. El hecho de que no se haya mitigado demuestra una falla grave en la **Gobernanza de TI** de la empresa.

8. Recordatorio: Actividad A04

Consigna A04 — Administración de Riesgos: Revisión de Caso

Revisión y Presentación del caso visto en clase (RetailCorp o el que se discuta en el aula). Deberás elaborar un informe formal de "Post-Mortem" que incluya:

1. Resumen ejecutivo del incidente.
2. Matriz de Riesgos (identificando al menos 3 riesgos críticos que permitieron el incidente).
3. Listado de Malas Prácticas identificadas.
4. Plan de Acción con Buenas Prácticas y Salvaguardas propuestas.

Subilo a la carpeta del Trabajo Integrador en Google Drive, otorgando permisos de comentario a era.profe@gmail.com.

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente» (4)
A. Recopilación de información	30 %	Utiliza de manera completa fuentes confiables (estándares, marcos de trabajo) y las cita correctamente para justificar las fallas.
B. Elaboración de documentos	30 %	Cumple adecuadamente con los formatos atento a la planilla de estandarización brindada por la cátedra.
C. Elaboración de presentaciones	10 %	Argumenta de manera sólida el inconveniente del caso y su solución (defiende el post-mortem).
F. Consciencia de buenas prácticas	30 %	Evidencia permanentemente el uso de buenas prácticas en el diseño de las salvaguardas propuestas.

9. Fuentes y bibliografía

9.1. Bibliografía obligatoria (según programa)

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Elgueta, R. (s.f.). *Guías de Clase unidad II*. Material inédito. UCH.

9.2. Bibliografía complementaria y Marcos de Trabajo

- Bancal, D. (2022). *Seguridad informática* (5.^a ed.). Ediciones ENI.
- ISO/IEC (2018). *ISO/IEC 27005: Information security risk management*.
- NIST (2012). *Guide for Conducting Risk Assessments (SP 800-30 Rev. 1)*.
- PCI Security Standards Council (2022). *Payment Card Industry Data Security Standard (PCI DSS) v4.0*. (Fundamental para entender los requisitos de redes POS).
- Mitre Corporation. *MITRE ATT&CK Framework*. (Para mapear técnicas de movimiento lateral).

9.3. Portales y recursos web

- Portales CERT, NIST, Hispasec.
- Plantilla de Matriz de Riesgos de la cátedra (Clase 4).
- Reportes de investigaciones de filtraciones de datos (DBIR) de Verizon.